

MANUAL DE ADMINISTRADOR

Sistema de Gestión de Lavado Vehicular (Vehicle Washing)

Gestión de usuarios y roles, configuración, pagos, reportes, respaldos, auditoría,
mantenimiento preventivo y resolución de incidencias

Tipo de manual	Manual de administrador (superusuarios y administradores de TI)
Integrantes	Brayan Estiven Patiño Cabrera (líder de proyecto) Juan Camilo Guilombo Osorio (líder de frontend) Merari Urbano (líder de backend)
Ficha	3145556
Programa	Tecnólogo en Análisis y Desarrollo de Software (ADSO)
Instructor/a	Karol Daniela Correa
Centro de formación	Industria
Fecha	06 de octubre de 2026
Versión	2.0

Control de versiones

La tabla siguiente registra el historial de cambios del presente documento. Cada vez que cambie una función administrativa, un procedimiento operativo o el estado de implementación de un módulo, debe agregarse una fila con la versión, la fecha, la descripción y el responsable.

Tabla 1

Historial de versiones del manual de administrador

Versión	Fecha	Descripción del cambio	Responsable
2.0	06/10/2026	Creación del manual de administrador a partir de la documentación del proyecto (versión del 02/10/2026), dentro de la versión 2.0 del conjunto de manuales.	Equipo desarrollador

Nota. Elaboración propia del equipo desarrollador.

Tabla de contenido

Control de versiones	2
4. Introducción	6
4.1 Fuentes y estado de la documentación	6
5. Objetivo	7
5.1 Objetivo general	7
5.2 Objetivos específicos	7
6. Alcance	8
6.1 Qué cubre este manual	8
6.2 Qué no cubre este manual	8
6.3 Estado de implementación de las funciones administrativas	8
7. Perfil del administrador	10
7.1 Quién es el administrador	10
7.2 Responsabilidades	10
7.3 Permisos y restricciones	10
7.4 Regla fundamental: cuentas individuales	11
8. Acceso al panel de administración	12
8.1 Requisitos de acceso	12
8.2 Ingreso al panel	12
8.3 Panel de control general	12
8.4 Primera cuenta de administrador	13
9. Gestión de usuarios	15
9.1 Principios de la gestión de cuentas	15
9.2 Consultar usuarios	15
9.3 Crear una cuenta de operario o de administrador	15
9.4 Activar y desactivar una cuenta	16
9.5 Restablecer la contraseña y desbloquear una cuenta	16
9.6 Sesiones activas	17
10. Gestión de roles y permisos	18
10.1 Los tres roles fijos	18
10.2 Control por rol y por propiedad	18

10.3 Consultar la asignación de roles y permisos	18
10.4 Cambiar el rol de una persona	19
11. Configuración del sistema	20
11.1 Datos del establecimiento	20
11.2 Horarios de atención y excepciones	20
11.3 Bahías de lavado	21
11.4 Medios de pago y código QR	21
11.5 Parámetros de seguridad de la plataforma	22
11.6 Variables de entorno de operación	23
12. Gestión de información principal	24
12.1 Operarios y disponibilidad	24
12.2 Servicios y precios	24
12.3 Asignar o reasignar un operario	25
12.4 Revisión y aprobación de pagos	25
12.5 Promociones	27
12.6 Reservas	27
12.7 Anuncios y notificaciones del sistema	28
13. Reportes administrativos	29
13.1 Consultas de apoyo	29
14. Copias de seguridad	31
14.1 Qué debe respaldarse	31
14.2 Política recomendada	31
14.3 Generar un respaldo manual	32
14.4 Automatizar el respaldo diario	33
14.5 Respaldo previo a cambios	33
15. Restauración de información	34
15.1 Cuándo restaurar	34
15.2 Procedimiento de restauración completa	34
15.3 Verificación posterior	35
15.4 Inicios de sesión de los servicios	35
15.5 Reversión de una migración	35
16. Auditoría o historial de acciones	37

16.1 Qué registra el sistema	37
16.2 Estructura de audit.audit_log	37
16.3 Consultas de auditoría	38
16.4 Interpretación de los registros sin autor	39
16.5 Revisión periódica y retención	39
17. Recomendaciones de seguridad	40
17.1 Cuentas y contraseñas	40
17.2 Datos personales	40
17.3 Secretos y configuración	40
17.4 Red y exposición	41
17.5 Riesgos aceptados que el administrador debe conocer	41
17.6 Mantenimiento preventivo	41
17.7 Resolución de incidencias	42
17.8 Niveles de severidad y escalamiento	44
18. Glosario	46
19. Anexos	47
Anexo A. Lista de figuras pendientes de captura	47
Anexo B. Información por confirmar antes de la entrega	47
Anexo C. Plantilla de registro de incidencias	47
Anexo D. Lista de chequeo de entrega	48
Referencias	49

4. Introducción

El Sistema de Gestión de Lavado Vehicular (Vehicle Washing) administra las reservas, la asignación de operarios, la ejecución de los servicios y la verificación de pagos de un establecimiento de lavado de vehículos. Dentro de ese sistema, el administrador es la persona que opera el negocio día a día y que, además, responde por la seguridad de las cuentas, la integridad de los datos y la continuidad del servicio.

Este manual está dirigido a superusuarios y administradores de tecnologías de la información. Explica cómo gestionar usuarios, roles y permisos; configurar el establecimiento, los horarios, las bahías y los medios de pago; administrar operarios, servicios, precios, reservas, pagos y promociones; obtener reportes; y, desde el punto de vista de infraestructura, realizar respaldos y restauraciones, consultar la auditoría, aplicar un plan de mantenimiento preventivo y resolver incidencias. Los controles de seguridad se alinean con las prácticas de gestión de riesgos del Instituto Nacional de Estándares y Tecnología de Estados Unidos (Ross et al., 2020) y con los principios de contingencia de la guía NIST SP 800-34 (Swanson et al., 2010).

4.1 Fuentes y estado de la documentación

El manual se elaboró a partir del repositorio de documentación del proyecto (requisitos, historias de usuario, decisiones de arquitectura, modelo de datos y políticas de seguridad). Dos limitaciones condicionan su contenido y se declaran de forma explícita:

- **No existen maquetas ni código del módulo de administración.** Las maquetas del repositorio cubren la autenticación, el cliente y el operario; el mapa de navegación solo registra la ruta */admin* con su panel (*AdminDashboard*), restringida al rol ADMIN. Por eso los procedimientos de las secciones 9, 11 y 12 se describen a nivel funcional, según los requisitos y las historias de usuario, sin inventar nombres de menús ni de botones; los nombres exactos deben confirmarse al capturar las pantallas finales.
- **Varias funciones administrativas aún no están terminadas.** Según las historias de usuario, la asignación manual de operarios y la revisión de pagos están *En progreso*, y la gestión de horarios, los reportes, las promociones y el panel por rol están en *Backlog*. La sección 6.3 resume ese estado. La guía ADSO pide no documentar módulos inexistentes (SENA, 2026); por esa razón, cada procedimiento indica el estado de su función y, mientras un módulo no exista, se ofrece un procedimiento alternativo a nivel de base de datos o de infraestructura que el administrador de TI puede ejecutar de forma controlada.

Cuando la documentación no define un dato (por ejemplo, una política de retención o un objetivo de recuperación), el manual lo señala como **recomendación** y lo lista en el Anexo B para que el equipo lo apruebe.

5. Objetivo

5.1 Objetivo general

Orientar al administrador en la gestión, la configuración y la supervisión del Sistema de Gestión de Lavado Vehicular, garantizando un uso seguro y organizado de la plataforma, la protección de sus datos y la continuidad de su operación.

5.2 Objetivos específicos

- Describir el perfil, las responsabilidades y las restricciones del administrador del sistema y del administrador de TI.
- Explicar la gestión del ciclo de vida de las cuentas, los tres roles fijos y los controles de acceso por rol y por propiedad del recurso.
- Detallar la configuración del establecimiento, los horarios, las bahías y los medios de pago, y la administración de operarios, servicios, precios, reservas, pagos y promociones.
- Presentar los reportes administrativos definidos y consultas de apoyo mientras el módulo de reportes no esté disponible.
- Establecer procedimientos verificables de respaldo, restauración y consulta de la auditoría.
- Proveer un plan de mantenimiento preventivo y una guía de resolución de incidencias.

6. Alcance

6.1 Qué cubre este manual

- Funciones del rol ADMIN en la aplicación: asignación de operarios, revisión de pagos, horarios, bahías, servicios y precios, promociones, medios de pago, anuncios y reportes.
- Gestión de cuentas y consulta de roles y permisos.
- Tareas de administración de TI sobre la base de datos SQL Server, RabbitMQ, los contenedores y los registros: respaldos, restauración, auditoría, mantenimiento y resolución de incidencias.

6.2 Qué no cubre este manual

- El uso del sistema por clientes y operarios (Manual de usuario).
- La arquitectura interna, el modelo de datos completo y los contratos de API (Manual técnico).
- La instalación inicial del entorno (Manual de instalación).
- Entornos de staging y producción, que la documentación declara fuera del alcance académico; las recomendaciones de este manual para esos entornos son orientativas.

6.3 Estado de implementación de las funciones administrativas

La tabla siguiente refleja el estado documentado el 02/10/2026. Debe actualizarse a medida que cada función se entregue, y confirmarse contra la versión final del software antes de publicar el manual.

Tabla 2***Estado documentado de las funciones administrativas***

Función	Referencia	Estado documentado	Sección
Asignar o reasignar un operario	HU-BOOK-006, RF-009	En progreso	12.3
Revisar y aprobar o rechazar pagos; confirmar efectivo	HU-PAY-003, RF-014	En progreso	12.4
Horarios de atención y excepciones	HU-ADMIN-001, RF-021	Backlog	11.2
Disponibilidad de operarios	HU-ADMIN-001, RF-022	Backlog	12.1
Reportes operativos	HU-ADMIN-001, RF-023	Backlog	13
Promociones y descuentos	HU-PROMO-001, RF-024	Backlog	12.5
Panel de control por rol	HU-UI-001, RF-017	Backlog (interfaz en construcción)	8.3
Crear cuentas con contraseña temporal y desactivarlas	ADR-010	Decidido; sin historia de usuario asociada	9
Roles y permisos de solo lectura	ADR-010	Decidido	10
Anuncios del sistema a los usuarios	ADR-011	Decidido (endpoint documentado)	12.7
RespalDOS, restauración y consulta de auditoría	Política de seguridad	No son módulos de la aplicación: se operan en la base de datos y la infraestructura	14, 15 y 16

Nota. Elaboración propia con base en las historias de usuario y en las ADR-010 y ADR-011.

7. Perfil del administrador

7.1 Quién es el administrador

El sistema define tres roles fijos: Administrador (código ADMIN), Operario (OPERATOR) y Cliente (CLIENT). El administrador es el dueño o el encargado del establecimiento. Este manual distingue dos perfiles que, según el tamaño del equipo, pueden recaer en una misma persona:

Tabla 3
Perfiles de administración

Perfil	Descripción	Ámbito
Administrador del negocio (rol ADMIN en la aplicación)	Opera el establecimiento a través del panel de administración.	Secciones 8, 9, 11, 12 y 13.
Administrador de TI (superusuario)	Responde por servidores, contenedores, base de datos, respaldos, auditoría y seguridad. No es un rol de la aplicación: actúa con cuentas de infraestructura.	Secciones 14 a 17 y los procedimientos de base de datos de otras secciones.

Nota. Elaboración propia. No existe un rol de superadministrador en el sistema: los tres roles son fijos y no se pueden crear roles personalizados (ADR-010).

7.2 Responsabilidades

- Mantener actualizados los datos del establecimiento, los horarios, las bahías, los servicios, los precios y los medios de pago.
- Asignar y reasignar operarios cuando el sistema no lo logre o se presente una ausencia.
- Revisar los pagos digitales contra el comprobante y confirmar los pagos en efectivo.
- Crear, desactivar y supervisar las cuentas de operarios y administradores.
- Consultar los reportes y la auditoría, y detectar comportamientos anómalos.
- Garantizar los respaldos, la capacidad de restauración y el mantenimiento preventivo.
- Atender las incidencias y documentarlas.

7.3 Permisos y restricciones

Permiso	Restricción
Gestiona operarios, horarios, bahías, servicios, precios, promociones y medios de pago.	Opera solo a través del panel y la API con su cuenta individual; el acceso directo a la base de datos corresponde al administrador de TI.
Revisa y aprueba o rechaza pagos.	No puede aprobar más de un pago para una misma reserva ni reutilizar una referencia de transacción ya aprobada en otro pago.

Permiso	Restricción
Ve la información de clientes, vehículos y reservas necesaria para operar.	Debe tratarla conforme a la Ley 1581 de 2012 y a la política de seguridad.
Desactiva cuentas.	No elimina cuentas: se desactivan y se conserva su historial.
Consulta los roles y los permisos.	No puede crear roles personalizados ni cambiar permisos desde la aplicación.

Nota. Fuente: requisitos funcionales, ADR-008, ADR-010 y política de seguridad. Todas las rutas bajo /admin exigen el rol ADMIN; un usuario sin ese rol es redirigido al panel general.

7.4 Regla fundamental: cuentas individuales

Cada persona que administre el sistema debe usar una cuenta individual y segura. No deben compartirse cuentas de administrador, porque la auditoría registra el usuario autor de cada cambio y una cuenta compartida impide atribuir responsabilidades. Quien deja de pertenecer al proceso debe tener su cuenta desactivada de inmediato.

8. Acceso al panel de administración

8.1 Requisitos de acceso

- Navegador actualizado (Chrome, Firefox o Edge) y conexión al sistema.
- Una cuenta con rol ADMIN, activa y no bloqueada.
- Para las tareas de TI: acceso al servidor o equipo donde se ejecutan los contenedores y a SQL Server con una cuenta de infraestructura (nunca la de un servicio).

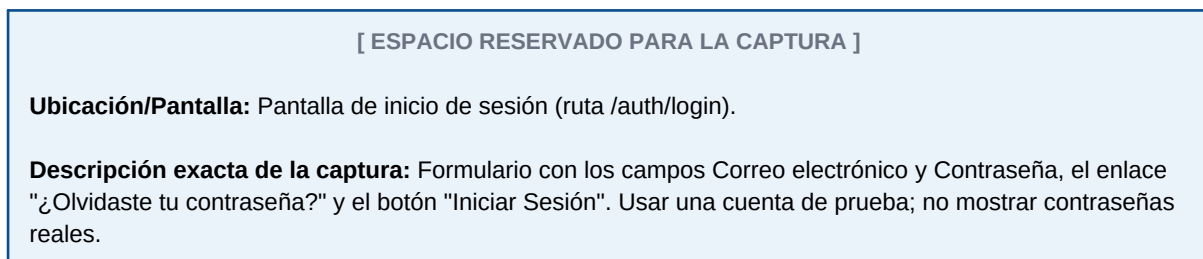
8.2 Ingreso al panel

- 1 Abrir la dirección web de la aplicación (en el entorno local, <http://localhost:4200>).
- 2 Hacer clic en **Iniciar sesión**.
- 3 Escribir el correo electrónico (terminación @gmail.com) y la contraseña de la cuenta de administrador.
- 4 Hacer clic en **Iniciar sesión**. El sistema valida las credenciales y redirige según el rol: la cuenta ADMIN accede al panel de administración (ruta */admin*).

Si la contraseña se escribe mal cinco veces dentro de un período de 15 minutos, la cuenta se bloquea durante 15 minutos. El token de acceso dura una hora; al vencer, el administrador debe volver a iniciar sesión. Si el usuario no tiene el rol ADMIN, cualquier ruta bajo */admin* lo redirige al panel general.

Figura 1

Inicio de sesión del administrador



8.3 Panel de control general

El panel de administración debe resumir lo que el administrador necesita para operar el día. El diseño en construcción contempla los elementos de la tabla siguiente; su estado de implementación debe confirmarse (historia HU-UI-001, en Backlog).

Tabla 4**Elementos previstos del panel de control del administrador**

Elemento	Información que muestra	Acción del administrador
Reservas de hoy	Número de reservas programadas para el día.	Revisar la carga de trabajo.
Servicios en progreso	Servicios que los operarios iniciaron y aún no finalizan.	Verificar el avance.
Pagos por verificar	Pagos en estado IN_REVIEW.	Ir a la revisión de pagos (sección 12.4).
Ingresos del día	Total de pagos aprobados en el día.	Contrastar con los reportes.
Ingresos de los últimos 7 días	Gráfico de ingresos diarios.	Detectar tendencias.
Estado de los operarios	Disponibilidad y servicios de cada operario.	Ajustar asignaciones.
Reservas sin operario	Reservas confirmadas que no tienen operario asignado.	Asignar manualmente (sección 12.3).

Nota. Elaboración propia con base en el diseño del panel en construcción y en las reglas de asignación. Si no hay datos, el panel debe mostrar un mensaje de que no hay registros todavía.

Figura 2**Panel de control general del administrador**

[ESPACIO RESERVADO PARA LA CAPTURA]	
Ubicación/Pantalla:	Panel de administración (ruta /admin).
Descripción exacta de la captura:	Pantalla completa con las tarjetas de reservas de hoy, servicios en progreso, pagos por verificar e ingresos del día, el gráfico de ingresos de los últimos 7 días, el estado de los operarios, los pagos pendientes de revisión y las reservas sin operario.

Nota. Capturar solo cuando el panel esté implementado, con datos de prueba.

8.4 Primera cuenta de administrador

Los datos iniciales del sistema cargan los tres roles, pero no incluyen ninguna cuenta de usuario. La documentación indica que las cuentas de operarios y administradores las crea un administrador con una contraseña temporal, pero **no define cómo se crea la primera cuenta administradora**. El procedimiento siguiente es una **propuesta** para el administrador de TI, sujeta a aprobación del equipo (Anexo B), porque una contraseña no puede insertarse directamente en SQL: se almacena cifrada con BCrypt, y solo la aplicación sabe generarla.

- 1 Registrar la cuenta desde la pantalla pública de registro, con el correo que será el del administrador. Esto crea la persona, la cuenta y el rol CLIENT con una contraseña válida.

- 2 Establecer el contexto de auditoría de la sesión de SQL Server con el identificador del administrador de TI, para que el cambio quede atribuido.
- 3 Asignar el rol ADMIN a la cuenta, con las consultas siguientes (los identificadores deben consultarse antes).
- 4 Cerrar la sesión y volver a ingresar; el sistema debe redirigir al panel de administración.
- 5 Registrar el cambio en el libro de incidencias o de cambios, con fecha, autor y motivo.

```
-- Identificadores necesarios
SELECT user_id, username FROM security.app_user WHERE username = N'<CORREO>';
SELECT role_id, code      FROM security.role;

-- Atribuir el cambio al administrador de TI en la auditoria
EXEC sp_set_session_context @key = N'user_id', @value = <ID_ADMIN_TI>;

-- Asignar el rol ADMIN
INSERT INTO security.user_role (user_id, role_id)
VALUES (<ID_USUARIO>, <ID_ROL_ADMIN>);
```

Debe confirmarse con el equipo de desarrollo si una misma cuenta puede tener a la vez los roles CLIENT y ADMIN, y si el redireccionamiento por rol la lleva al panel esperado; si no, debe retirarse el rol CLIENT con el mismo cuidado. Esta operación debe ejecutarse una sola vez, con una cuenta de infraestructura y no con la de un servicio.

9. Gestión de usuarios

Una cuenta del sistema se compone de una persona (*security.person*, con documento, nombres, teléfono y correo) y de una cuenta de acceso (*security.app_user*, con usuario, contraseña cifrada, estado activo y fecha del último ingreso). Los roles se asignan en *security.user_role*. La contraseña se almacena únicamente como hash BCrypt y ningún administrador, ni siquiera el de TI, puede verla ni recuperarla (OWASP Foundation, 2021).

9.1 Principios de la gestión de cuentas

- **Las cuentas se desactivan, no se eliminan.** Al desactivar una cuenta, la persona ya no puede ingresar y se cierran todas sus sesiones; las reservas, los pagos y las calificaciones se conservan (ADR-010).
- **Un correo, una cuenta.** El correo (terminación @gmail.com) es el usuario de ingreso y es único.
- **Ningún dato de dominio se borra físicamente.** El borrado es lógico mediante *deleted_at*; el administrador no debe ejecutar sentencias DELETE sobre tablas de dominio.
- **Mínimo privilegio.** Se asigna solo el rol necesario y se retira cuando deja de serlo.

9.2 Consultar usuarios

El módulo de usuarios del panel de administración debe listar las cuentas con su rol y estado. Mientras no exista, el administrador de TI puede obtener el mismo listado con la consulta siguiente, que no expone contraseñas:

```
SELECT u.user_id, u.username, p.first_name, p.last_name,
       r.code AS rol, u.is_active, u.last_login
FROM security.app_user u
JOIN security.person    p  ON p.person_id = u.person_id
LEFT JOIN security.user_role ur ON ur.user_id = u.user_id
LEFT JOIN security.[role]  r  ON r.role_id  = ur.role_id
ORDER BY u.user_id;
```

Figura 3

Listado de usuarios

[ESPACIO RESERVADO PARA LA CAPTURA]	
Ubicación/Pantalla:	Panel de administración, módulo de usuarios (a confirmar).
Descripción exacta de la captura:	Tabla con nombre, correo, rol, estado (activo o inactivo) y fecha del último ingreso, con filtros por rol y estado, y el botón para crear una cuenta.

Nota. Si el módulo no existe, capturar el resultado de la consulta anterior sin datos personales reales.

9.3 Crear una cuenta de operario o de administrador

La documentación establece que el administrador crea la cuenta con una contraseña temporal, que la persona debe cambiar en su primer ingreso (ADR-010). Los clientes se registran solos.

- 1 Ingresar con una cuenta de administrador y abrir el módulo de usuarios.
- 2 Seleccionar la opción para crear un usuario.
- 3 Diligenciar documento, nombres, teléfono, correo (@gmail.com) y rol (Operario o Administrador).
- 4 Definir una contraseña temporal que cumpla la política: mínimo 8 caracteres, una mayúscula, un número y un carácter especial. Debe generarse de forma aleatoria y entregarse por un canal privado.
- 5 Dejar el estado en **Activo** y guardar.
- 6 Verificar que la cuenta aparezca en el listado y que la persona pueda ingresar y cambiar la contraseña.
- 7 Para un operario, registrar además su disponibilidad semanal (sección 12.1).

Estado de la función. No existe una historia de usuario ni un endpoint documentado para esta operación. Hasta que se confirme, la creación de la cuenta del operario puede hacerse con el registro público seguido de la asignación del rol y de la ficha de operario por parte del administrador de TI (sección 12.1).

9.4 Activar y desactivar una cuenta

La ADR-010 define el endpoint *PATCH /admin/users/{id}/status* para activar o desactivar una cuenta. Antes de desactivar, debe verificarse que la cuenta no sea la única con rol ADMIN.

- 1 Localizar la cuenta en el módulo de usuarios.
- 2 Seleccionar la acción de desactivar y confirmar el cuadro de diálogo.
- 3 Comprobar que el estado cambia a inactivo y que la persona ya no puede ingresar.
- 4 Si la persona es un operario con servicios pendientes, reasignarlos (sección 12.3) antes o inmediatamente después.

La reactivación se hace con la misma acción. En todos los casos el cambio queda registrado en la auditoría (sección 16).

9.5 Restablecer la contraseña y desbloquear una cuenta

El administrador no puede ver ni fijar la contraseña de un usuario. Para recuperar el acceso, la persona usa la opción **¿Olvidaste tu contraseña?**: recibe un código de seis dígitos en su correo, vigente 15 minutos y con cinco intentos. Un código nuevo invalida el anterior y un cambio exitoso levanta también el bloqueo por intentos fallidos.

Tabla 5
Situaciones de acceso y acción del administrador

Situación	Causa	Acción
La persona olvidó su contraseña	—	Indicar el flujo de recuperación; verificar que el correo esté bien escrito en <i>security.person</i> .
La cuenta está bloqueada	Cinco intentos fallidos en 15 minutos.	Esperar 15 minutos o recuperar la contraseña. Un reinicio del servicio de seguridad también borra los contadores (están en memoria).
No llega el código	Correo mal escrito, MAIL_ENABLED desactivado o fallo del SMTP.	Revisar el correo registrado y el servicio de correo (sección 17.7).
La persona cambió de correo	Cambio desde su perfil con contraseña actual.	Informarle que el nuevo correo es ahora su usuario.

Nota. Fuente: requisitos RF-003, RF-004 y RF-004b, y ADR-010.

9.6 Sesiones activas

Cada ingreso queda en *security.user_session* (inicio, vencimiento, revocación, IP y agente de navegador). Cerrar sesión o desactivar la cuenta marca la fila como revocada. Importante: un token JWT ya emitido no puede revocarse antes de vencer (una hora); es un riesgo aceptado del diseño (ADR-006). Ante una sospecha de compromiso, se desactiva la cuenta, se cambia el secreto del JWT si el compromiso es de la plataforma y se revisa la auditoría.

```
SELECT TOP (50) s.user_session_id, u.username, s.started_at, s.expires_at,
               s.revoked_at, s.ip_address, s.user_agent
FROM security.user_session s
JOIN security.app_user u ON u.user_id = s.user_id
ORDER BY s.started_at DESC;
```

10. Gestión de roles y permisos

10.1 Los tres roles fijos

El sistema tiene tres roles fijos y no admite roles personalizados ni superadministrador (ADR-010). La base de datos guarda los códigos ADMIN, OPERATOR y CLIENT. Los roles y sus permisos se muestran en la aplicación en modo de solo lectura.

Tabla 6

Matriz de roles y permisos principales

Capacidad	ADMIN	OPERATOR	CLIENT
Registrar y gestionar sus vehículos	—	—	Sí (propios)
Crear, modificar y cancelar reservas	Crear en nombre de un cliente	—	Sí (propias)
Ver servicios asignados	Todos	Solo los suyos	—
Iniciar y finalizar un servicio	—	Solo los asignados a él	—
Asignar o reasignar operario	Sí	—	Elegir al reservar (si se implementa)
Pagar y cargar comprobantes	—	—	Sí (propios)
Aprobar o rechazar pagos	Sí	—	—
Calificar un servicio finalizado	—	—	Sí, una vez
Configurar horarios, servicios, precios, promociones	Sí	—	—
Gestionar cuentas	Sí	—	Solo la suya
Consultar reportes	Sí	Sus calificaciones	—

Nota. Elaboración propia con base en los requisitos funcionales y en la política de seguridad.

10.2 Control por rol y por propiedad

Un rol válido no basta: cada servicio verifica además la propiedad del recurso. Un operario con token válido no puede actualizar la ejecución de otro operario, y un cliente solo alcanza sus propias reservas, vehículos y pagos. El gateway rechaza en el borde los tokens inválidos y cada servicio vuelve a validarlos y declara el rol que exige. Una petición de un rol a un recurso de otro devuelve 403.

10.3 Consultar la asignación de roles y permisos

El esquema de seguridad contiene permisos granulares (recurso y acción) heredados del núcleo compartido, pero los requisitos solo piden control por rol; hoy el rol es la unidad de autorización. La consulta siguiente muestra los permisos que la base asigna a cada rol:

```
SELECT r.code AS rol, p.code AS permiso, p.resource, p.[action]
FROM security.role_permission rp
JOIN security.[role]      r ON r.role_id = rp.role_id
JOIN security.permission p ON p.permission_id = rp.permission_id
ORDER BY r.code, p.resource, p.[action];
```

10.4 Cambiar el rol de una persona

El cambio de rol es una operación sensible. Debe seguirse el procedimiento siguiente, que idealmente la aplicación ofrece y, mientras no exista, ejecuta el administrador de TI:

- 1 Registrar la solicitud: quién la pide, quién la aprueba, el rol actual, el nuevo y el motivo.
- 2 Verificar la identidad de la persona.
- 3 Establecer el contexto de auditoría (*sp_set_session_context*) con el identificador del administrador de TI.
- 4 Modificar la asignación en *security.user_role*; no crear una segunda fila si el rol anterior debe retirarse.
- 5 Si el nuevo rol es OPERATOR, crear la ficha en *execution.operator* (sección 12.1).
- 6 Pedir a la persona que cierre sesión e ingrese de nuevo, para que su token refleje el nuevo rol.
- 7 Comprobar el cambio en la auditoría y archivar la solicitud.

Figura 4

Roles y permisos en modo de solo lectura

[ESPACIO RESERVADO PARA LA CAPTURA]

Ubicación/Pantalla: Panel de administración, módulo de roles y permisos (a confirmar).

Descripción exacta de la captura: Pantalla con los tres roles (Administrador, Operario y Cliente) y la lista de permisos de cada uno, sin controles de edición.

11. Configuración del sistema

Esta sección agrupa los parámetros que definen el comportamiento del establecimiento y de la plataforma. Los datos del establecimiento, los horarios, las bahías y los medios de pago viven en las tablas de los esquemas *booking* y *payment*; cualquier cambio queda en la auditoría.

11.1 Datos del establecimiento

El sistema atiende un solo establecimiento. Su registro (*booking.establishment*, una sola fila garantizada por la columna *singleton*) contiene la razón social, el nombre comercial, el NIT, la dirección, el teléfono, el correo y el logotipo, que se usan en el encabezado de recibos y en las pantallas de contacto y ayuda.

- 1 Abrir el módulo de configuración del establecimiento.
- 2 Revisar razón social, nombre comercial, NIT, dirección, teléfono y correo.
- 3 Modificar los campos que cambiaron y guardar.
- 4 Comprobar que el encabezado de los recibos y la pantalla de ayuda muestran los datos nuevos.

11.2 Horarios de atención y excepciones

El horario semanal (*booking.business_hour*) define, para cada día de la semana, la hora de apertura y de cierre y, de forma opcional, un descanso (por ejemplo, el almuerzo). Las excepciones (*booking.business_hour_exception*) cubren festivos, cierres y horarios especiales: cada una tiene una fecha única, si el día está cerrado, las horas especiales y el motivo. Un cambio aplica a las verificaciones de disponibilidad futuras; las reservas ya confirmadas no se reubican solas.

Tabla 7
Parámetros del horario

Parámetro	Descripción	Regla
Día de la semana	Día al que aplica la fila.	Una fila por día.
Apertura y cierre	Horas entre las que se aceptan reservas.	El cierre debe ser posterior a la apertura.
Descanso (inicio y fin)	Franja sin atención dentro del día.	Opcional; debe estar dentro del horario.
Excepción: fecha	Día que no sigue el horario normal.	Una excepción por fecha.
Excepción: cerrado	El establecimiento no abre ese día.	Si está cerrado, no se admiten reservas.
Excepción: motivo	Razón del cambio (festivo, mantenimiento).	Obligatorio.

Nota. Fuente: modelo de datos y HU-ADMIN-001. Estado documentado: Backlog.

Antes de registrar un cierre o un horario especial, debe consultarse si existen reservas confirmadas ese día, para contactar a los clientes y reubicarlas:

```
SELECT b.booking_id, b.scheduled_start, b.scheduled_end, st.code AS estado
FROM booking.booking b
JOIN booking.booking_status st ON st.booking_status_id = b.booking_status_id
WHERE CAST(b.scheduled_start AS date) = '<AAAA-MM-DD>'
AND st.code IN ('SCHEDULED', 'CONFIRMED') AND b.deleted_at IS NULL;
```

Figura 5

Configuración de horarios y excepciones

[ESPACIO RESERVADO PARA LA CAPTURA]

Ubicación/Pantalla: Panel de administración, módulo de horarios (a confirmar).

Descripción exacta de la captura: Tabla de los siete días con apertura, cierre y descanso, y una lista de excepciones con fecha, estado cerrado y motivo.

11.3 Bahías de lavado

Una bahía es un puesto físico de lavado y su número define la capacidad del negocio: dos reservas activas no pueden ocupar la misma bahía en rangos de tiempo superpuestos. El estado de la bahía (*booking.bay_status*) puede ser ACTIVE, MAINTENANCE o INACTIVE; solo las bahías que aceptan reservas se consideran en la disponibilidad. La bahía se elige por reserva y el operario por ejecución: no existe un turno fijo de operario por bahía (ADR-010).

- 1 Abrir el módulo de bahías.
- 2 Para crear una bahía, registrar código y nombre y dejarla en estado ACTIVE.
- 3 Para una reparación, cambiar el estado a MAINTENANCE; la bahía deja de recibir reservas nuevas.
- 4 Antes de poner una bahía en MAINTENANCE o INACTIVE, consultar las reservas futuras asignadas a ella y reubicarlas.
- 5 Al terminar el mantenimiento, regresar el estado a ACTIVE.

11.4 Medios de pago y código QR

Cada método de pago tiene una fila en *payment.payment_account*, que guarda el titular, el número de cuenta, la imagen del código QR, las instrucciones y si está activo. Los métodos son efectivo, Nequi, Daviplata y transferencia bancaria; el efectivo no tiene QR ni exige comprobante. Esta es la información que ve el cliente al pagar y por eso debe revisarse con cuidado: un QR o una cuenta equivocados envían el dinero del negocio a un tercero.

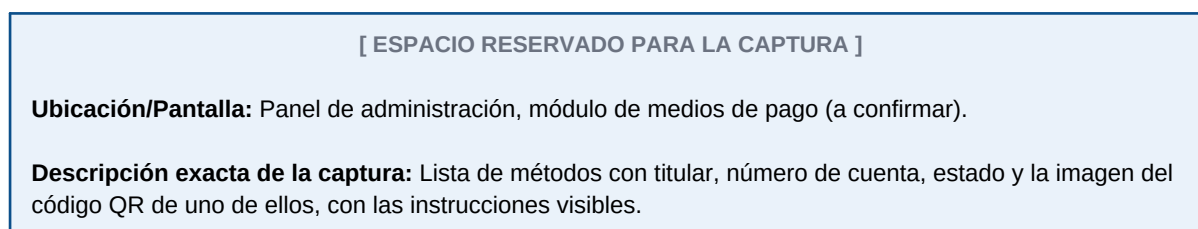
- 1 Abrir el módulo de medios de pago.

- 2 Seleccionar el método (por ejemplo, Nequi).
- 3 Actualizar titular, número de cuenta, imagen del QR e instrucciones.
- 4 Activar o desactivar el método según se acepte o no.
- 5 Probar escaneando el QR desde una cuenta de prueba y verificar que el titular mostrado es el del negocio.

Almacenamiento de imágenes. La ubicación final, los formatos aceptados y el tamaño máximo de las imágenes de QR y de los comprobantes son decisiones pendientes (ADR-008). Mientras se definen, el administrador de TI debe incluir el directorio o volumen que las contenga en el respaldo (sección 14).

Figura 6

Configuración de medios de pago



Nota. Usar una cuenta y un QR de prueba.

11.5 Parámetros de seguridad de la plataforma

Tabla 8

Parámetros de seguridad vigentes

Parámetro	Valor	Dónde se configura
Vigencia del token de acceso	1 hora	security-service (no editable desde la interfaz).
Bloqueo de cuenta	5 intentos fallidos en 15 minutos; bloqueo de 15 minutos	security-service.
Código de recuperación	6 dígitos; vigencia de 15 minutos; 5 intentos	security-service.
Contraseña	Mínimo 8 caracteres, una mayúscula, un número, un carácter especial	Validación del servicio y de la interfaz.
Cifrado de contraseñas	BCrypt	security-service.
Algoritmo de firma del JWT	HS256 con secreto de al menos 32 caracteres	Variable de entorno compartida.
Idioma y tema por usuario	Español, inglés, francés, portugués; tema a elección	Preferencias del usuario.

Nota. Fuente: ADR-006 y política de seguridad. El documento de ejemplo de la guía ADSO propone 30 minutos de inactividad; este sistema no usa inactividad sino una hora de vigencia fija.

11.6 Variables de entorno de operación

Las variables que cambian el comportamiento de la plataforma se leen del archivo *.env* y requieren reiniciar el servicio afectado. Las más relevantes para el administrador de TI son: *MESSAGING_ENABLED* (activa RabbitMQ), *PUSH_ENABLED* (activa el envío push), *MAIL_ENABLED* y *MAIL_** (correo), *BOOKING_ZONE* (zona horaria de las horas reservables) y *CUSTOMER_SERVICE_URL* y *CUSTOMER_SERVICE_TIMEOUT* (comunicación entre servicios). Los valores y el procedimiento de cambio se describen en el Manual de instalación.

12. Gestión de información principal

12.1 Operarios y disponibilidad

Un operario es una persona con cuenta de rol OPERATOR y una ficha en *execution.operator* (usuario, fecha de contratación, especialidad y estado activo). Su disponibilidad semanal (*execution.operator_availability*) indica los días y las horas en que puede recibir trabajo, y las ausencias puntuales (*execution.operator_absence*: inicio, fin y motivo) reemplazan esa disponibilidad. La asignación automática solo elige operarios cuyo horario cubre el turno y que no tienen una ausencia que se superponga (HU-ADMIN-001, RF-022).

- 1 Crear la cuenta de operario (sección 9.3) y confirmar que su ficha está activa.
- 2 Registrar la disponibilidad semanal: día, hora de inicio y hora de fin, una fila por franja.
- 3 Para una incapacidad, vacaciones o permiso, registrar la ausencia con fechas y motivo.
- 4 Consultar el estado de los operarios en el panel y ajustar las franjas cuando cambie el turno.
- 5 Para retirar a un operario, desactivar su ficha y su cuenta, y reasignar sus servicios futuros (sección 12.3).

Figura 7

Disponibilidad y ausencias de un operario

[ESPACIO RESERVADO PARA LA CAPTURA]

Ubicación/Pantalla: Panel de administración, módulo de operarios (a confirmar).

Descripción exacta de la captura: Ficha del operario con su especialidad, la tabla semanal de disponibilidad y la lista de ausencias con fechas y motivo.

12.2 Servicios y precios

El catálogo contiene categorías de servicio (*catalog.service_category*), servicios (*catalog.service*: código, nombre, descripción y estado) y precios (*catalog.service_price*), donde cada precio corresponde a un par servicio-tipo de vehículo con valor, duración estimada y fechas de vigencia. Los combos son servicios de la categoría de paquetes; las promociones son cupones de descuento aparte (ADR-010).

Regla de inmutabilidad. El precio de una línea de reserva se fija al crear la línea y no cambia si el catálogo cambia después; una regla de base de datos impide modificar un precio que ya se usó. Por eso, para cambiar un precio no se edita el existente: se cierra su vigencia (*valid_to*) y se crea uno nuevo con la fecha de inicio nueva.

- 1 Abrir el módulo de servicios y precios.
- 2 Para un servicio nuevo, registrar código, nombre, descripción y categoría.

- 3 Para cada tipo de vehículo, crear el precio con valor, duración estimada y fecha de inicio.
- 4 Para actualizar un precio, cerrar la vigencia del anterior y crear el nuevo desde la fecha deseada.
- 5 Para dejar de ofrecer un servicio, desactivarlo; las reservas existentes no se alteran.
- 6 Verificar en la pantalla del cliente que el valor mostrado es el nuevo.

12.3 Asignar o reasignar un operario

El sistema asigna automáticamente a cada reserva confirmada el operario elegible con menos trabajos abiertos; los empates se resuelven a favor del identificador de operario más bajo (RF-008). Si ningún operario está disponible, se notifica al cliente y al administrador, y la reserva queda sin operario hasta que este intervenga. El administrador puede asignar o reasignar manualmente (HU-BOOK-006, en progreso).

- 1 Abrir la lista de reservas sin operario del panel, o la reserva que se desea reasignar.
- 2 Seleccionar la acción de asignar o reasignar.
- 3 Elegir un operario de la lista de disponibles para ese turno.
- 4 Indicar el motivo si es una reasignación (ausencia, equilibrio de carga).
- 5 Confirmar. El nuevo operario recibe una notificación y el anterior queda liberado de ese servicio.

Si se elige un operario que no está disponible en ese turno, el sistema bloquea la asignación y explica el motivo. Cada reasignación conserva su historial en *execution.service_reassignment* (operario anterior y nuevo, motivo, autor y fecha), de modo que puede auditarse quién movió qué.

Figura 8

Asignación manual de un operario

[ESPACIO RESERVADO PARA LA CAPTURA]

Ubicación/Pantalla: Panel de administración, reserva o lista de reservas sin operario.

Descripción exacta de la captura: Ventana de asignación con la reserva, el turno, la lista de operarios disponibles, el campo de motivo y el botón de confirmar.

12.4 Revisión y aprobación de pagos

El sistema no integra una pasarela de pagos (ADR-008). El cliente paga fuera de la plataforma con el QR del negocio y carga el comprobante; el administrador verifica que el dinero llegó y aprueba o rechaza. Es la función más sensible del rol, porque autoriza el cobro de un servicio. Los estados de un pago son PENDING, IN_REVIEW, APPROVED, REJECTED y REFUNDED.

Tabla 9
Controles de la revisión de pagos

Control	Cómo lo aplica el sistema	Qué debe hacer el administrador
Monto	El monto declarado en el comprobante se guarda aparte del adeudado.	Comparar ambos; un monto distinto es motivo de rechazo o revisión.
Referencia de transacción	No puede reutilizarse en otro pago aprobado.	Si se rechaza por referencia repetida, indicarlo en el motivo.
Un solo pago aprobado	Una reserva no admite más de un pago aprobado.	No intentar aprobar un segundo pago de la misma reserva.
Historial	Los intentos rechazados se conservan.	No borrar intentos rechazados.
Verificación real	El sistema no consulta al banco.	Confirmar en la aplicación o el extracto del negocio que el dinero se recibió, no solo mirar la imagen.

Nota. Fuente: ADR-008, RF-014 y RF-016.

Aprobar un pago digital.

- 1 Abrir la lista de pagos en revisión (estado IN_REVIEW).
- 2 Seleccionar el pago y abrir el comprobante.
- 3 Verificar que el valor, la referencia, la fecha y el titular coinciden con la transferencia recibida en la cuenta del negocio.
- 4 Verificar que el monto declarado es igual al adeudado de la reserva.
- 5 Hacer clic en **Aprobar**. El pago pasa a APPROVED, el cliente recibe una notificación y se acumulan sus puntos de fidelidad.

Rechazar un pago. Si el valor no coincide, el comprobante es ilegible o no se puede verificar, el administrador selecciona **Rechazar** y escribe un motivo claro (máximo 200 caracteres). El cliente recibe el motivo y puede enviar un nuevo intento.

Confirmar un pago en efectivo. Cuando el cliente paga en el establecimiento, el administrador confirma que recibió el dinero y aprueba el pago directamente; no se requiere comprobante.

Pendiente de decisión. La documentación no define si un servicio puede comenzar antes de que el pago se apruebe (ADR-008). Hasta que se decida, el administrador debe fijar y comunicar una política operativa.

Figura 9**Lista de pagos en revisión**

[ESPACIO RESERVADO PARA LA CAPTURA]

Ubicación/Pantalla: Panel de administración, módulo de pagos.

Descripción exacta de la captura: Tabla de pagos en estado IN_REVIEW con reserva, cliente, método, monto declarado, monto adeudado y fecha de carga, con el botón para abrir cada comprobante.

Figura 10**Revisión de un comprobante**

[ESPACIO RESERVADO PARA LA CAPTURA]

Ubicación/Pantalla: Módulo de pagos, detalle de un pago.

Descripción exacta de la captura: Imagen del comprobante junto a los datos de la reserva, el monto declarado y la referencia, con los botones Aprobar y Rechazar y el campo de motivo.

Nota. Usar un comprobante de prueba, sin datos bancarios reales.

12.5 Promociones

Una promoción (*promotion.promotion*) tiene código, tipo de descuento (porcentaje o monto fijo), valor, tope de descuento, compra mínima, ventana de vigencia, si es pública, topes de uso global y por cliente, y estado. Puede restringirse a servicios o asignarse a clientes concretos. El cliente la aplica con el código al pagar; si está vencida o no aplica, el sistema avisa y el precio original se mantiene (HU-PROMO-001 y 002, en Backlog).

- 1 Abrir el módulo de promociones y seleccionar la opción de crear.
- 2 Definir código, nombre, tipo y valor del descuento.
- 3 Establecer fecha de inicio y de fin, tope de descuento y compra mínima.
- 4 Fijar los límites de uso total y por cliente, para controlar el costo de la campaña.
- 5 Si aplica, restringirla a servicios o asignarla a clientes específicos.
- 6 Guardar, probar el código con una cuenta de prueba y comprobar el descuento.
- 7 Para terminar una campaña, desactivar la promoción: los clientes ya no pueden aplicarla a pagos nuevos.

Fidelidad. Los puntos se acreditan cuando el pago se aprueba, a razón de un punto por cada 1.000 COP (valor por confirmar con el responsable del producto). El saldo oficial es el libro *payment.loyalty_transaction*; el campo de puntos del cliente es solo una copia de visualización. La redención aún no está implementada.

12.6 Reservas

El administrador puede crear una reserva en nombre de un cliente y listar las reservas de un día. Las reglas de ciclo de vida son las mismas para todos: la cancelación se bloquea una vez el servicio está en ejecución, y una reserva no puede quedar fuera del horario ni ocupar una bahía ocupada.

Tabla 10
Estados de la reserva y acción del administrador

Estado	Significado	Acción posible del administrador
SCHEDULED	Creada, a la espera de confirmación.	Revisar, asignar operario.
CONFIRMED	Con turno y bahía.	Asignar o reasignar operario.
IN_PROGRESS	El operario inició el lavado.	Supervisar; no se cancela.
COMPLETED	Servicio finalizado.	Confirmar el pago.
CANCELLED	Anulada por el cliente o el establecimiento.	Consultar el motivo.
NO_SHOW	El cliente no se presentó.	Registrar y revisar patrones.

Nota. Códigos de la base de datos según la ADR-010; la interfaz los traduce.

El total de una reserva no se almacena: se calcula con las líneas y sus precios menos el descuento por puntos. Cuando un turno no es viable (por ejemplo, un cierre inesperado), el administrador contacta al cliente y cancela con un motivo del catálogo *booking.cancellation_reason*.

12.7 Anuncios y notificaciones del sistema

El administrador puede enviar un mensaje a los usuarios mediante el endpoint *POST /api/v1/admin/notifications* (tipo *SYSTEM_MESSAGE*), que sirve también para probar las notificaciones. El mensaje se guarda siempre en la bandeja del usuario; el envío push es adicional y su fallo no impide el registro. Las notificaciones push requieren una compilación de la aplicación móvil con EAS y la variable *PUSH_ENABLED* en true. Los textos deben ser breves, en español y sin datos personales de terceros.

13. Reportes administrativos

La historia HU-ADMIN-001 define que el administrador debe ver los servicios realizados, los ingresos, la calificación promedio y el desempeño por operario (RF-023). El módulo está en Backlog; hasta su entrega, los mismos indicadores pueden obtenerse con las consultas de esta sección. La exportación a PDF o Excel no está definida en la documentación.

Tabla 11
Reportes administrativos definidos

Reporte	Contenido	Origen de los datos
Servicios realizados	Servicios finalizados por período, servicio y operario.	execution.service_execution
Ingresos	Pagos aprobados por día, mes y método.	payment.payment
Calificación promedio	Promedio de calificaciones por operario y servicio.	execution.service_execution
Desempeño por operario	Servicios finalizados, calificación y reasignaciones.	execution y service_reassignment
Pagos por estado	Cantidad y valor de pagos por estado.	payment.payment
Usuarios	Cuentas por rol y estado.	security.app_user

Nota. Elaboración propia con base en RF-023 y el alcance del sistema.

13.1 Consultas de apoyo

Ingresos aprobados por día (los pagos no guardan el método directamente, sino la cuenta de pago):

```
SELECT CAST(p.processed_at AS date) AS dia,
       COUNT(*) AS pagos,
       SUM(p.amount) AS ingresos
FROM payment.payment p
JOIN payment.payment_status ps ON ps.payment_status_id = p.payment_status_id
WHERE ps.code = 'APPROVED' AND p.deleted_at IS NULL
      AND p.processed_at >= DATEADD(day, -30, SYSUTCDATETIME())
GROUP BY CAST(p.processed_at AS date)
ORDER BY dia DESC;
```

Las fechas se almacenan en UTC; para informes por día calendario de Colombia, debe restarse cinco horas antes de convertir a fecha.

Desempeño por operario:

```
SELECT o.operator_id, COUNT(*) AS servicios,
       AVG(CAST(se.quality_rating AS float)) AS calificacion_promedio,
       COUNT(se.quality_rating) AS calificados
FROM execution.service_execution se
JOIN execution.operator o ON o.operator_id = se.operator_id
JOIN execution.execution_status es ON es.execution_status_id = se.execution_status_id
WHERE es.code = 'FINALIZADA' AND se.deleted_at IS NULL
```

```
GROUP BY o.operator_id  
ORDER BY servicios DESC;
```

Pagos pendientes de revisión, el indicador más urgente de la jornada:

```
SELECT p.payment_id, p.booking_id, p.amount, r.reported_amount,  
       r.transaction_reference, r.uploaded_at  
FROM payment.payment p  
JOIN payment.payment_status ps ON ps.payment_status_id = p.payment_status_id  
LEFT JOIN payment.payment_receipt r ON r.payment_id = p.payment_id  
WHERE ps.code = 'IN_REVIEW' AND p.deleted_at IS NULL  
ORDER BY r.uploaded_at;
```

Las consultas de reporte son de solo lectura. Deben ejecutarse con una cuenta de consulta y no con la de un servicio, y fuera de las horas de mayor demanda si la base es grande. Los datos de clientes que contengan no deben copiarse a hojas de cálculo compartidas sin autorización.

Figura 11

Reportes administrativos

[ESPACIO RESERVADO PARA LA CAPTURA]

Ubicación/Pantalla: Panel de administración, módulo de reportes (a confirmar).

Descripción exacta de la captura: Pantalla con filtros de fecha, las tarjetas de servicios realizados, ingresos y calificación promedio, y la tabla de desempeño por operario.

14. Copias de seguridad

La documentación del proyecto no define una estrategia de respaldo, porque la producción está fuera de su alcance, y la aplicación no incluye un módulo de copias de seguridad. Por tanto, los respaldos son una tarea del administrador de TI sobre SQL Server y los volúmenes de Docker. Esta sección propone un procedimiento basado en las prácticas de planificación de contingencias (Swanson et al., 2010) y en la documentación de SQL Server (Microsoft, s. f.). Los valores marcados como recomendación deben aprobarse por el equipo (Anexo B).

14.1 Qué debe respaldarse

Tabla 12

Elementos que deben incluirse en el respaldo

Elemento	Contenido	Cómo se respalda
Base de datos de SQL Server	Los nueve esquemas, la auditoría (<i>audit.audit_log</i>) y las tablas de control de Liquibase.	BACKUP DATABASE completo.
Archivos de imágenes	Imágenes de QR y comprobantes de pago, si se guardan en disco (ubicación aún no definida, ADR-008).	Copia del volumen o directorio que las contenga.
Archivo .env	Secreto del JWT, contraseñas y variables del entorno.	Copia cifrada y guardada aparte de los respaldos de datos; nunca en el repositorio.
Definición del entorno	Archivo de Docker Compose y repositorios de código.	Ya versionados en Git; verificar que el remoto está al día.
Inicios de sesión de SQL Server	Los inicios de sesión de cada servicio viven en el servidor, no en la base.	Guardar el script de creación en un lugar seguro.

Nota. Elaboración propia. Una base de datos respaldada sin sus inicios de sesión y sin las imágenes de comprobantes no se recupera por completo.

14.2 Política recomendada

Tabla 13**Política de respaldos recomendada**

Aspecto	Recomendación
Frecuencia	Un respaldo completo diario, fuera de las horas de reservas, y otro inmediatamente antes de cada migración o cambio importante.
Retención	14 respaldos diarios, 8 semanales y 12 mensuales.
Regla 3-2-1	Tres copias, en dos medios distintos, una de ellas fuera del equipo donde corre el sistema.
Nombre del archivo	backup_<base>_AAAA-MM-DD_HHMM.bak (por ejemplo, backup_lavado_2026-10-06_0200.bak).
Cifrado y acceso	Almacenar en una carpeta con acceso restringido y cifrar las copias que salgan del equipo: contienen datos personales protegidos por la Ley 1581 de 2012.
Objetivos de recuperación	Pérdida máxima aceptable de datos (RPO): 24 horas. Tiempo máximo de recuperación (RTO): 4 horas.
Verificación	Comprobar cada respaldo y restaurar uno en un entorno de prueba al menos una vez al mes.

Nota. Recomendaciones de este manual; no provienen de la documentación del proyecto.

14.3 Generar un respaldo manual

El respaldo se genera dentro del contenedor y luego se copia al anfitrión. Los marcadores entre ángulos deben sustituirse con los valores del entorno; la ruta de *sqlcmd* depende de la imagen (en las imágenes 2022 es */opt/mssql-tools18/bin/sqlcmd*).

- 1 Verificar que hay espacio libre en el disco: un respaldo ocupa, como orden de magnitud, el tamaño de los datos.
- 2 Generar el respaldo con suma de verificación.
- 3 Comprobar que el archivo es legible.
- 4 Copiarlo al anfitrión y luego al almacenamiento seguro.
- 5 Registrar el respaldo (fecha, archivo, tamaño, resultado de la verificación y responsable).

1) Respaldo completo dentro del contenedor

```
docker compose exec <SERVICIO_SQLSERVER> /opt/mssql-tools18/bin/sqlcmd \
```

```
-S localhost -U sa -P "<CONTRASENA_SA>" -C -Q \
```

```
"BACKUP DATABASE [<BD>] TO DISK = N'/var/opt/mssql/data/backup_<BD>_2026-10-06_0200.bak' WITH INIT, CHECKSUM"
```

2) Verificar que el archivo es restaurable

```
docker compose exec <SERVICIO_SQLSERVER> /opt/mssql-tools18/bin/sqlcmd \
```

```
-S localhost -U sa -P "<CONTRASENA_SA>" -C -Q \
```

```
"RESTORE VERIFYONLY FROM DISK = N'/var/opt/mssql/data/backup_<BD>_2026-10-06_0200.bak' WITH CHECKSUM"
```

3) Copiar al anfitrión

```
docker cp <CONTENEDOR_SQLSERVER>:/var/opt/mssql/data/backup_<BD>_2026-10-06_0200.bak ./respaldos/
```

La opción *WITH CHECKSUM* detecta páginas dañadas al respaldar y al verificar. Si se genera el respaldo con la cuenta *sa*, debe hacerse solo desde una sesión del administrador de TI; la contraseña no debe quedar en el historial del terminal ni en un guion compartido (en un guion, se lee de una variable de entorno).

Figura 12

Respaldo generado y verificado

[ESPACIO RESERVADO PARA LA CAPTURA]

Ubicación/Pantalla: Terminal del administrador de TI.

Descripción exacta de la captura: Salida de BACKUP DATABASE con el número de páginas procesadas y de RESTORE VERIFYONLY con el mensaje de que el conjunto de respaldo es válido.

14.4 Automatizar el respaldo diario

Un respaldo que depende de que alguien lo recuerde termina por no hacerse. En Linux puede programarse con *cron*; en Windows, con el Programador de tareas. El siguiente guion de ejemplo genera el respaldo, lo verifica, lo copia y elimina los archivos que superan la retención:

```
#!/usr/bin/env bash
set -euo pipefail
FECHA=$(date +%F_%H%M)
ARCH="backup_<BD>_${FECHA}.bak"
DEST="$HOME/respaldos"
SQL="docker compose -f $HOME/lavarapido/lavarapido-infra/docker-compose.yml exec -T <SERVICIO_SQLSERVER> /opt/

$SQL -Q "BACKUP DATABASE [<BD>] TO DISK=N'/var/opt/mssql/data/$ARCH' WITH INIT,CHECKSUM,COMPRESSION"
$SQL -Q "RESTORE VERIFYONLY FROM DISK=N'/var/opt/mssql/data/$ARCH' WITH CHECKSUM"
docker cp <CONTENEDOR_SQLSERVER>:/var/opt/mssql/data/$ARCH "$DEST/"
find "$DEST" -name 'backup_<BD>_*.bak' -mtime +14 -delete
echo "$(date -Is) OK $ARCH" >> "$DEST/respaldos.log"

# crontab -e (todos los días a las 2:00 a. m.; SA_PASSWORD viene del entorno del usuario)
0 2 * * * /home/<USUARIO>/bin/respaldo.sh >> /home/<USUARIO>/respaldos/cron.log 2>&1
```

El guion debe guardarse con permisos restringidos, y debe vigilarse su resultado: una alerta si el archivo del día no existe vale más que cien respaldos que nadie revisa. El nombre del archivo de configuración de Compose y de las rutas debe confirmarse en el repositorio de infraestructura.

14.5 Respaldo previo a cambios

- Antes de aplicar migraciones de Liquibase (*liquibase update*), generar un respaldo y anotar el último changeset aplicado.
- Antes de cambiar el rol de varias cuentas, de modificar precios masivamente o de reasignar operarios en lote, generar un respaldo.
- No ejecutar *docker compose down -v* en un entorno con datos que importen: elimina el volumen de la base de datos.

15. Restauración de información

Restaurar sobrescribe los datos actuales con los del respaldo: se pierde todo lo registrado después de este. Por eso la restauración debe ser una decisión autorizada y registrada, nunca una reacción improvisada.

15.1 Cuándo restaurar

Tabla 14

Escenarios de restauración

Escenario	Decisión
Base de datos dañada o contenedor perdido sin volumen	Restauración completa desde el último respaldo válido.
Cambio masivo erróneo (por ejemplo, precios o roles)	Restaurar en una base temporal, extraer los datos correctos y corregir la base de producción; evitar sobrescribirla si hay datos nuevos.
Migración fallida	Restaurar el respaldo previo a la migración y revisar el changeset.
Compromiso de seguridad	Restaurar en un entorno limpio, cambiar secretos y contraseñas antes de reabrir el acceso.
Prueba periódica	Restaurar en un entorno de prueba, nunca sobre el real.

Nota. Elaboración propia.

15.2 Procedimiento de restauración completa

- 1 Obtener la autorización y anunciar la interrupción a los usuarios (sección 12.7).
- 2 Elegir el respaldo y comprobar su integridad con RESTORE VERIFYONLY.
- 3 Detener los servicios de aplicación y el gateway para que no escriban durante la restauración; dejar SQL Server encendido.
- 4 Hacer un respaldo del estado actual, aunque esté dañado, para no perder la evidencia.
- 5 Copiar el archivo de respaldo al contenedor y restaurarlo.
- 6 Verificar la estructura y los datos (sección 15.3).
- 7 Si se restauró en un servidor nuevo, recrear los inicios de sesión de cada servicio y reasociar los usuarios (sección 15.4).
- 8 Iniciar los servicios en el orden de arranque y ejecutar las pruebas de verificación.
- 9 Restaurar también las imágenes de comprobantes, si están en disco, desde su respaldo.
- 10 Registrar la restauración y comunicar a los usuarios la fecha y hora del último dato recuperado.

```
# Detener los servicios de aplicacion (la base sigue encendida)
docker compose stop <SERVICIO_GATEWAY> security-service customer-service booking-service \
operations-service payment-service notification-service

# Copiar el respaldo al contenedor
docker cp ./respaldos/<ARCHIVO>.bak <CONTENEDOR_SQLSERVER>:/var/opt/mssql/data/

# Restaurar (cierra conexiones abiertas y reemplaza la base)
docker compose exec <SERVICIO_SQLSERVER> /opt/mssql-tools18/bin/sqlcmd \
-S localhost -U sa -P "<CONTRASENA_SA>" -C -b -Q \
"ALTER DATABASE [<BD>] SET SINGLE_USER WITH ROLLBACK IMMEDIATE;
RESTORE DATABASE [<BD>] FROM DISK = N'/var/opt/mssql/data/<ARCHIVO>.bak' WITH REPLACE, CHECKSUM, STATS = 10;
ALTER DATABASE [<BD>] SET MULTI_USER;"
```

La opción *WITH REPLACE* sobrescribe la base existente: debe usarse solo cuando se está seguro del respaldo elegido. Si el comando falla a la mitad, la base puede quedar en estado de restauración o en modo de un solo usuario; no debe reiniciarse el contenedor sin revisar el registro de SQL Server.

15.3 Verificación posterior

- Los nueve esquemas existen y las tablas de catálogo tienen sus filas (consultas del Manual de instalación, sección 11.6).
- Los identificadores fijos siguen en su lugar: *booking_status_id* = 5 (CANCELLED) y *payment_status_id* = 3 (APPROVED).
- La última fila de *audit.audit_log* y la última reserva corresponden a la fecha esperada del respaldo.
- Un administrador puede ingresar y una cuenta de prueba de cliente puede consultar sus reservas.
- La tabla *DATABASECHANGELOG* refleja el último changeset aplicado en ese respaldo.

Se debe revisar si los datos creados entre el respaldo y la falla pueden reconstruirse (por ejemplo, correos de confirmación enviados, notificaciones, pagos que los clientes hicieron fuera del sistema). Los pagos transferidos a la cuenta del negocio y no registrados por la restauración deben contrastarse con el extracto bancario y recuperarse con los clientes.

15.4 Inicios de sesión de los servicios

Los inicios de sesión de SQL Server pertenecen al servidor, no a la base. Al restaurar en un servidor nuevo, los usuarios de la base quedan huérfanos. Se reasocian con el inicio de sesión recreado:

```
USE [<BD>];
-- por cada servicio, tras recrear su LOGIN en el servidor
ALTER USER [<LOGIN_SERVICIO>] WITH LOGIN = [<LOGIN_SERVICIO>];
```

15.5 Reversión de una migración

Los changesets de Liquibase son siempre hacia adelante y no tienen bloques de reversión. Por tanto, deshacer una migración equivale a restaurar el respaldo previo y corregir el changeset con uno nuevo; nunca debe editarse un changeset ya ejecutado.

Figura 13***Verificación posterior a la restauración***

[ESPACIO RESERVADO PARA LA CAPTURA]

Ubicación/Pantalla: Terminal o cliente SQL.

Descripción exacta de la captura: Resultado de las consultas de verificación: los nueve esquemas, los identificadores fijos de estado y las últimas filas de auditoría.

16. Auditoría o historial de acciones

16.1 Qué registra el sistema

El sistema deja rastro por tres vías complementarias: la tabla *audit.audit_log*, que registra los cambios sobre los datos mediante disparadores de la base de datos; la tabla *security.user_session*, que registra los ingresos; y los registros de los servicios en la salida estándar de los contenedores. La auditoría no la publican los servicios como eventos; la produce la base de datos (ADR-009).

Tabla 15
Fuentes de auditoría

Fuente	Qué contiene	Uso típico
audit.audit_log	Entidad, identificador, acción, datos anteriores y nuevos, autor y fecha de cada cambio.	Quién cambió un precio, un rol o el estado de un pago.
security.user_session	Ingresos: usuario, inicio, vencimiento, revocación, IP y agente.	Detectar ingresos inusuales.
security.app_user.last_login	Último ingreso de cada cuenta.	Identificar cuentas sin uso.
execution.service_reassignment	Reasignaciones: operario anterior y nuevo, motivo, autor y fecha.	Revisar el equilibrio de carga.
payment.payment_receipt	Quién cargó y quién revisó cada comprobante, y cuándo.	Revisar quién aprobó cada pago.
Registros de los contenedores	Errores de arranque, de conexión y de reglas; incluyen el identificador de correlación.	Diagnosticar incidencias.

Nota. Fuente: política de seguridad, ADR-009 y modelo de datos. Los registros nunca deben contener contraseñas, tokens ni el contenido de los comprobantes (Kent y Souppaya, 2006).

16.2 Estructura de audit.audit_log

Tabla 16
Columnas de audit.audit_log

Columna	Descripción
audit_log_id	Identificador del registro.
entity	Tabla o entidad modificada.
entity_id	Identificador de la fila modificada.
action	Tipo de cambio (inserción, actualización, borrado lógico).
previous_data	Valores anteriores (texto JSON), si aplica.
new_data	Valores nuevos (texto JSON), si aplica.
changed_by	Identificador del usuario autor; sale del contexto de sesión que establece cada servicio.
changed_at	Fecha y hora del cambio, en UTC.

Nota. Fuente: modelo de datos (esquema audit).

16.3 Consultas de auditoría

Últimos cambios de la plataforma:

```
SELECT TOP (100) audit_log_id, entity, entity_id, [action], changed_by, changed_at
FROM audit.audit_log
ORDER BY changed_at DESC;
```

Historia de una fila concreta (por ejemplo, un pago):

```
SELECT changed_at, [action], changed_by, previous_data, new_data
FROM audit.audit_log
WHERE entity = N'payment' AND entity_id = <ID_PAGO>
ORDER BY changed_at;
```

Cambios hechos por una persona en un rango de fechas:

```
SELECT changed_at, entity, entity_id, [action]
FROM audit.audit_log
WHERE changed_by = <ID_USUARIO>
AND changed_at >= '<AAAA-MM-DD>' AND changed_at < '<AAAA-MM-DD>'
ORDER BY changed_at;
```

Cambios sin autor, que indican un defecto de la aplicación o un cambio hecho directamente en la base de datos:

```
SELECT TOP (100) audit_log_id, entity, entity_id, [action], changed_at
FROM audit.audit_log
WHERE changed_by IS NULL
ORDER BY changed_at DESC;
```

La columna *entity* debe consultarse primero con un *SELECT DISTINCT entity*, porque los valores exactos no están enumerados en la documentación. Los datos anteriores y nuevos pueden contener información personal; su consulta y su copia deben limitarse a quien lo necesite.

16.4 Interpretación de los registros sin autor

El disparador lee el autor de `SESSION_CONTEXT(N'user_id')`, que cada servicio debe establecer al inicio de cada petición. Si un servicio olvida hacerlo, el cambio queda con *changed_by* vacío sin producir un error visible. Es un riesgo identificado de probabilidad alta (ADR-009). Cuando el administrador de TI modifique datos directamente en la base, debe establecer ese contexto con su identificador, como en la sección 8.4, para que la acción quede atribuida.

16.5 Revisión periódica y retención

- Revisar semanalmente los cambios sobre roles, cuentas, precios, medios de pago y estados de pago.
- Revisar los ingresos y las cuentas con ingresos fuera de horario o desde direcciones nuevas.
- Investigar de inmediato todo cambio de rol ADMIN o de datos de QR y cuentas de pago.
- La documentación no define una política de retención. Recomendación: conservar la auditoría como mínimo 12 meses en línea y archivar la anterior en los respaldos mensuales; la tabla solo crece, por lo que debe vigilarse su tamaño (sección 17.6).
- No modificar ni borrar filas de *audit.audit_log*: pierde su valor probatorio.

Figura 14

Consulta del historial de auditoría

[ESPACIO RESERVADO PARA LA CAPTURA]

Ubicación/Pantalla: Cliente SQL o sqlcmd.

Descripción exacta de la captura: Resultado de la consulta de los últimos cambios, con entidad, acción, autor y fecha, sin datos personales reales visibles.

17. Recomendaciones de seguridad

La política de seguridad del proyecto se basa en la defensa en profundidad, el mínimo privilegio, la falla segura, la seguridad por diseño y la confianza cero. Las recomendaciones siguientes se alinean con los controles de seguridad y privacidad del NIST (Joint Task Force, 2020) y con el estándar OWASP (OWASP Foundation, 2021).

17.1 Cuentas y contraseñas

- No compartir la contraseña de administrador y usar cuentas individuales.
- Usar contraseñas únicas, largas y guardadas en un gestor de contraseñas; cambiar de inmediato cualquier contraseña temporal.
- Desactivar las cuentas de personas que ya no pertenecen al proceso el mismo día de su salida.
- Revisar trimestralmente la lista de administradores: debe ser la más corta posible.
- Cerrar sesión al terminar y no ingresar desde equipos compartidos; el token dura una hora.
- No usar la cuenta de administrador para tareas de cliente; si es necesario, usar una cuenta distinta.

17.2 Datos personales

El sistema trata datos personales (documento, nombres, teléfono, correo, vehículos y pagos) y debe cumplir la Ley Estatutaria 1581 de 2012 (Congreso de la República de Colombia, 2012). El administrador solo debe consultar los datos que necesita para su función, no copiarlos a medios personales ni compartirlos por mensajería, y debe atender las solicitudes de consulta o corrección de los titulares. No se recolectan datos de tarjetas. Los respaldos y exportaciones heredan la obligación de protección.

17.3 Secretos y configuración

- El archivo `.env` no se versiona y tiene permisos restringidos; el repositorio solo contiene `.env.example`.
- El secreto del JWT (mínimo 32 caracteres) y las contraseñas de `sa`, de los servicios y de RabbitMQ deben cambiarse antes de cualquier despliegue compartido, y de inmediato ante sospecha de compromiso. Cambiar el secreto del JWT invalida todos los tokens emitidos y obliga a todos a volver a ingresar.
- Los servicios no se conectan con la cuenta `sa`: cada uno usa un inicio de sesión con derechos solo sobre sus esquemas.
- Las credenciales de demostración de los datos semilla nunca llegan a un despliegue público.

17.4 Red y exposición

- Solo el gateway debe quedar expuesto fuera de la red de Docker; SQL Server, RabbitMQ y Mailpit no deben ser accesibles desde fuera del equipo.
- Fuera del entorno local, usar HTTPS con TLS 1.2 o superior.
- El gateway no aplica límite de peticiones (ADR-005): la defensa contra fuerza bruta es el bloqueo de cuenta. Si el sistema se expone a internet, debe revisarse esta decisión.

17.5 Riesgos aceptados que el administrador debe conocer

Tabla 17

Riesgos aceptados y medida del administrador

Riesgo	Medida recomendada
Un token JWT no se revoca antes de vencer (1 hora).	Desactivar la cuenta y, si es grave, rotar el secreto del JWT.
Firma HS256 con secreto compartido entre servicios.	Proteger el .env y rotar el secreto periódicamente.
Los contadores de bloqueo están en memoria; un reinicio los borra.	Evitar reinicios innecesarios del servicio de seguridad.
Sin Outbox, un evento puede perderse entre la confirmación y la publicación.	Revisar notificaciones faltantes y la cola de mensajes fallidos.
Instancia compartida de SQL Server para los seis servicios.	Respalidar con frecuencia y limitar quién accede a la instancia.
Verificación de pagos manual.	Confirmar siempre contra el extracto del negocio.

Nota. Fuente: ADR-004, ADR-005, ADR-006 y política de seguridad.

17.6 Mantenimiento preventivo

El mantenimiento preventivo reduce la probabilidad de incidencias y debe programarse en el calendario del administrador de TI. La tabla siguiente es una propuesta de este manual; las frecuencias deben ajustarse a la operación real.

Tabla 18
Plan de mantenimiento preventivo

Frecuencia	Tarea	Cómo verificarla
Diaria	Confirmar que el respaldo se generó y se verificó.	Archivo del día y registro de respaldos.
Diaria	Revisar los contenedores y los errores de los servicios.	<code>docker compose ps</code> y <code>docker compose logs --since 24h</code> .
Diaria	Revisar pagos pendientes de revisión y reservas sin operario.	Panel o consultas de la sección 13.
Semanal	Revisar la cola de mensajes fallidos de RabbitMQ.	Cola <code>notification-service.events.dlq</code> en cero.
Semanal	Revisar el espacio en disco, el volumen de SQL Server y los registros.	Uso por debajo del 80 %; rotación de registros activa.
Semanal	Revisar auditoría: roles, precios, medios de pago, estados de pago.	Consultas de la sección 16.
Mensual	Probar la restauración de un respaldo en un entorno de prueba.	Verificación posterior de la sección 15.3.
Mensual	Comprobar la integridad de la base de datos.	<code>DBCC CHECKDB</code> sin errores.
Mensual	Revisar actualizaciones de imágenes base y parches de seguridad.	Versiones de SQL Server, RabbitMQ, Mailpit y Docker.
Mensual	Revisar el crecimiento de <code>audit.audit_log</code> y de las tablas de sesiones.	Tamaño por tabla.
Trimestral	Revisar cuentas y roles: cuentas sin uso, administradores vigentes.	Consulta de usuarios y último ingreso.
Trimestral	Revisar dependencias vulnerables.	<code>mvn versions:display-dependency-updates</code> y <code>npm audit</code> .
Trimestral	Rotar secretos (JWT, contraseñas de servicios y de RabbitMQ).	Pruebas de ingreso posteriores.
Anual	Revisar festivos y horarios del año siguiente; revisar este manual.	Excepciones cargadas; control de versiones.

Nota. Elaboración propia con base en la política de seguridad y en las prácticas de contingencia (Swanson et al., 2010).

```
# Verificaciones de salud rapidas
docker compose ps
docker stats --no-stream
docker system df
```

```
docker compose exec <SERVICIO_SQLSERVER> /opt/mssql-tools18/bin/sqlcmd -S localhost -U sa -P "<CONTRASENA_SA>"
-Q "DBCC CHECKDB ([<BD>]) WITH NO_INFOMSGS"
```

17.7 Resolución de incidencias

Una incidencia se atiende con un método fijo: detectar, contener, diagnosticar, corregir, verificar y documentar. El primer paso del diagnóstico es consultar el registro del servicio afectado, que lleva marca de tiempo, nivel, nombre del servicio e identificador de correlación; con ese identificador se sigue una petición a través del gateway y los servicios.

```
docker compose ps
docker compose logs --tail 100 <servicio>
docker compose logs --since 30m booking-service | grep -i error
```

Tabla 19
Incidencias frecuentes del administrador

Incidencia	Causa probable	Resolución
Un usuario no puede ingresar	Contraseña olvidada, cuenta bloqueada o desactivada.	Verificar estado en <i>app_user</i> ; recuperar contraseña o esperar el desbloqueo de 15 minutos.
Todos reciben 401	Token vencido o secreto del JWT distinto entre servicios.	Volver a iniciar sesión; verificar que el secreto es el mismo en todos los servicios.
No se pueden crear reservas (503)	customer-service caído o mal configurado.	Reiniciar el servicio; revisar <i>CUSTOMER_SERVICE_URL</i> y <i>CUSTOMER_SERVICE_TIMEOUT</i> .
Reservas que quedan sin operario	No hay operarios disponibles o ausencias sin registrar.	Asignar manualmente; revisar disponibilidades y ausencias.
Un pago no se puede aprobar	Ya hay un pago aprobado para la reserva o la referencia se usó antes.	Revisar el historial de pagos de la reserva y rechazar el duplicado.
Un pago aprobado sin que haya llegado dinero	Comprobante falso o mal verificado.	Revisar la auditoría de quién aprobó; contactar al cliente; registrar y corregir mediante el procedimiento de reembolso.
No llegan notificaciones	MESSAGING_ENABLED en false, RabbitMQ caído o mensajes en la cola fallida.	Activar la mensajería, iniciar RabbitMQ y revisar la cola <i>notification-service.events.dlq</i> .
No llega el código de recuperación	MAIL_ENABLED desactivado o SMTP mal configurado.	Revisar <i>MAIL_*</i> y, en local, la interfaz de Mailpit.
Cambios sin autor en la auditoría	Un servicio no establece <i>SESSION_CONTEXT</i> .	Informar al equipo de desarrollo; el filtro común debe corregirse.
Horas desfasadas	Zona horaria mal configurada; el sistema almacena UTC.	Revisar <i>BOOKING_ZONE</i> y la conversión en el cliente.
Disco lleno	Registros, respaldos o crecimiento de datos.	Liberar espacio de forma segura, rotar registros y mover respaldos; nunca borrar archivos de datos de SQL Server.
La base no responde	Contenedor detenido, memoria insuficiente o archivo dañado.	Revisar los registros de SQL Server y la memoria asignada a Docker; si hay daño, restaurar (sección 15).
Sospecha de cuenta comprometida	Ingresos inusuales, cambios no reconocidos.	Desactivar la cuenta, revisar sesiones y auditoría; si es grave, rotar secretos.

Nota. Elaboración propia con base en las decisiones y los riesgos documentados. Los problemas de instalación se detallan en el Manual de instalación, sección 17.

17.8 Niveles de severidad y escalamiento

Tabla 20***Severidad recomendada de las incidencias***

Severidad	Ejemplo	Respuesta objetivo
Crítica	Sistema caído, pérdida de datos o cuenta de administrador comprometida.	Inmediata; avisar al líder del proyecto.
Alta	No se pueden reservar o pagar servicios.	En la misma jornada.
Media	Notificaciones o correos que no llegan.	En 2 días hábiles.
Baja	Texto o formato incorrecto.	Siguiente entrega.

Nota. Recomendación de este manual; los tiempos deben ser aprobados por el equipo.

Toda incidencia debe quedar en un registro con fecha, quién la detectó, descripción, severidad, causa, acciones, resultado y acciones para evitar su repetición (Anexo C). Si la incidencia exige un cambio del software, se reporta al equipo de desarrollo con el identificador de correlación y los registros del servicio.

18. Glosario

Tabla 21**Glosario de términos de administración**

Término	Definición
Administrador	Rol ADMIN: opera el establecimiento y administra cuentas, pagos y configuración.
Auditoría	Registro de los cambios de datos con su autor y fecha.
Bahía	Puesto físico de lavado; su número define la capacidad del negocio.
BCrypt	Algoritmo con el que se almacenan cifradas las contraseñas.
Borrado lógico	Marca de eliminación mediante <i>deleted_at</i> ; la fila no se borra.
Comprobante	Imagen o archivo que demuestra una transferencia.
Desactivar	Impedir el ingreso de una cuenta conservando su historial.
DLQ	Cola donde se guardan los mensajes que fallaron tras los reintentos.
Hash	Resultado irreversible de cifrar un dato, como una contraseña.
JWT	Token firmado que identifica al usuario y su rol; dura una hora.
Libro de puntos	Tabla <i>payment.loyalty_transaction</i> , fuente oficial del saldo de puntos.
Mínimo privilegio	Principio de dar a cada cuenta solo los permisos que necesita.
RPO	Pérdida máxima de datos aceptable, medida en tiempo.
RTO	Tiempo máximo aceptable para recuperar el servicio.
Respaldo	Copia de la base de datos que permite recuperarla.
SESSION_CONTEXT	Mecanismo de SQL Server que pasa el usuario actual a los disparadores de auditoría.
Severidad	Nivel de gravedad de una incidencia.

Nota. Elaboración propia con base en la documentación del proyecto.

19. Anexos

Anexo A. Lista de figuras pendientes de captura

Antes de la entrega, el equipo debe reemplazar cada espacio reservado por una captura real, nítida y ordenada según el flujo. Las capturas del módulo de administración solo pueden tomarse cuando este exista. Ninguna captura debe mostrar contraseñas, cuentas bancarias, códigos QR reales ni datos personales reales.

Anexo B. Información por confirmar antes de la entrega

Tabla 22

Información pendiente de confirmar

Tema	Qué falta o qué se contradice	Sección
Módulo de administración	No hay maquetas ni código; los nombres de menús, botones y pantallas son funcionales y deben confirmarse.	8 a 13
Estado de cada función	Varias funciones están en Backlog o En progreso.	6.3
Primera cuenta administradora	No hay un procedimiento definido; el de la sección 8.4 es una propuesta.	8.4
Creación de cuentas por el administrador	La ADR-010 la menciona, pero no hay historia ni endpoint documentado.	9.3
Coexistencia de roles	Falta confirmar si una cuenta puede tener a la vez los roles CLIENT y ADMIN.	8.4 y 10.4
Política de respaldos y objetivos RPO y RTO	No definidos; los valores propuestos deben aprobarse.	14
Almacenamiento de comprobantes y QR	Ubicación, formatos y tamaño pendientes.	11.4 y 14
Pago y ejecución del servicio	No está definido si el servicio puede iniciar antes de la aprobación del pago.	12.4
Puntos de fidelidad	Equivalencia de un punto por 1.000 COP por confirmar; la redención no está implementada.	12.5
Retención de la auditoría	No hay política definida.	16.5
Valores de la columna entity	No están enumerados en la documentación.	16.3
Exportación de reportes	No se define PDF ni Excel.	13
Nombres de servicios de Compose, base de datos y rutas	Dependen del repositorio de infraestructura.	14 y 15

Nota. Elaboración propia a partir del análisis de la documentación del proyecto.

Anexo C. Plantilla de registro de incidencias

Tabla 23
Registro de una incidencia

Campo	Contenido
Fecha y hora de detección	
Detectada por	
Descripción y síntomas	
Severidad	Crítica / Alta / Media / Baja
Servicios afectados	
Identificador de correlación o registros	
Causa	
Acciones realizadas y responsable	
Resultado y hora de cierre	
Acciones para evitar su repetición	

Anexo D. Lista de chequeo de entrega

Tabla 24
Lista de chequeo del manual de administrador

Criterio	Cumple
Portada completa y versión	Sí / No
Tabla de contenido con páginas actualizadas	Sí / No
Objetivo y alcance explicados	Sí / No
El contenido coincide con el módulo de administración de la versión final	Sí / No
Todas las figuras reemplazadas por capturas reales	Sí / No
Procedimientos de respaldo y restauración probados en una instalación real	Sí / No
Sin credenciales, claves ni datos sensibles	Sí / No
Pendientes del Anexo B resueltos	Sí / No
Exportado en PDF con el nombre Manual_administrador_NombreProyecto_Ficha.pdf	Sí / No

Nota. Adaptada de la lista de chequeo de la guía ADSO (SENA, 2026).

Referencias

Congreso de la República de Colombia. (2012). *Ley Estatutaria 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales*.

Equipo desarrollador. (2026). *Documentación del Sistema de Gestión de Lavado Vehicular (Vehicle Washing)* [Repositorio de documentación del proyecto]. Programa Tecnólogo en Análisis y Desarrollo de Software, SENA.

Joint Task Force. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-53r5>

Kent, K., y Souppaya, M. (2006). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-92>

Microsoft. (s. f.). *Back up and restore of SQL Server databases*. Microsoft Learn. <https://learn.microsoft.com/sql/relational-databases/backup-restore/back-up-and-restore-of-sql-server-databases>

OWASP Foundation. (2021). *OWASP Top 10:2021*. <https://owasp.org/Top10/>

Servicio Nacional de Aprendizaje [SENA]. (2026). *Guía para elaborar manuales de software: Manual de usuario, manual técnico, manual de instalación y manual de administrador*. Tecnólogo en Análisis y Desarrollo de Software.

Swanson, M., Bowen, P., Phillips, A. W., Gallup, D., y Lynes, D. (2010). *Contingency planning guide for federal information systems* (NIST Special Publication 800-34, Rev. 1). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-34r1>